

NETWORK DEVICE MANAGEMENT POLICY

Based on SANS/CRF Cybersecurity Policy Template, February 2026
Network Security Category

Version	Effective Date	Document Owner	Status
1.0	March 28, 2026	Noe Valencia	Active

Do not distribute externally.

1. Purpose

This Network Device Management Policy establishes a comprehensive, enforceable framework for the secure configuration, monitoring, and lifecycle management of all network devices within our organization. Network devices including routers, switches, firewalls, and wireless access points form the critical backbone of our IT infrastructure. Their compromise directly threatens the confidentiality, integrity, and availability of every system and service they support.

This policy provides clear, actionable guidelines for administering, maintaining, and protecting these devices. It implements controls aligned to the SANS/CRF Cybersecurity Policy Template (February 2026), CIS Benchmarks, NIST frameworks, and current industry best practices. By enforcing secure configurations, structured patch management, privileged access controls, and continuous monitoring, this policy seeks to minimize the risk of unauthorized access, data breaches, and network disruptions and to ensure resilience against the accelerating, AI-driven threat landscape of 2026.

2. Scope

This policy applies to all employees, contractors, vendors, and third parties who administer, configure, access, monitor, or otherwise interact with network devices owned, leased, or operated by this organization. It covers all network devices regardless of physical location including on-premises, co-located, hosted, and cloud-managed environments:

- Routers and Layer 3 switching equipment
- Layer 2 switches and managed network infrastructure
- Firewalls, next-generation firewalls (NGFW), and unified threat management (UTM) appliances
- Wireless access points, WLAN controllers, and wireless infrastructure
- Virtual network devices, software-defined networking (SDN), and SD-WAN components
- Network management, monitoring, and IPAM systems
- Any device that performs network routing, switching, or security filtering functions

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval through the exception process defined in Section 11.

3. Principle Statement

Network device security is managed on the principle of least privilege and Zero Trust. No device, user, or system is inherently trusted, and every access request to a network device must be continuously verified regardless of origin. This policy operates under the assumption that the network may be compromised at any time, requiring persistent authentication, authorization, and monitoring at every administrative access point.

All decisions regarding network device management are guided by the CIA Triad: Confidentiality (preventing unauthorized access to device configurations and data), Integrity (ensuring configurations remain accurate and unmodified without authorization), and Availability (ensuring network devices remain operational and resilient against disruption). Controls are prioritized based on risk. Devices controlling critical infrastructure or handling sensitive data receive the most stringent safeguards.

4. Senior Management Commitment

The leadership of this organization is fully committed to the implementation and ongoing enforcement of this Network Device Management Policy. We recognize that our network devices represent critical infrastructure assets whose compromise could result in significant operational, financial, reputational, and legal harm to the organization and those we serve.

Senior management directs all relevant personnel to adhere to the safeguards and procedures defined herein, and commits to providing the resources, training, tools, and governance oversight necessary for effective implementation. This policy will be reviewed no less than annually and updated in response to material changes in the threat environment, applicable standards, or organizational infrastructure.

Signed: _____ Date: _____
Chief Information Security Officer / Senior IT Leadership

5. How Similar Organizations Handle Network Device Management

Researching peer organizations reveals consistent patterns in how effective network device management policies are structured, enforced, and maintained. The following examples demonstrate real-world approaches that inform the controls in this policy.

5.1 University of Bristol, ISP-12 (Approved November 2025)

The University of Bristol's ISP-12 Network Management Policy, approved November 2025 under its ISO/IEC 27001-aligned Information Security Policy framework, demonstrates a mature approach used by large higher-education institutions. Key practices include requiring all network devices to be located in physically secured communications rooms with access restricted to authorized staff; subjecting all network changes to a formal IT change management process before implementation; prohibiting unauthorized WLAN equipment from connecting to the institutional network without IT Services approval; assigning IP address management responsibility exclusively to IT Services; and enforcing strict network boundary controls including firewalls at all internet gateways. Bristol explicitly references ITIL for change management and the Data Protection Act 2018/GDPR for legal compliance, demonstrating how regulatory obligations are embedded directly into network policy.

5.2 Government and Federal Sector, NIST/DISA Baseline

Federal agencies and defense contractors operating under NIST SP 800-53 and DISA STIGs implement network device management through rigorous configuration baselines, mandatory use of out of band management networks, prohibition of all unencrypted management protocols (Telnet is explicitly banned), required use of centralized authentication (TACACS+ or RADIUS with MFA), and automated configuration compliance scanning using tools like CIS-CAT Pro and OpenSCAP. The January 2026 NSA/CISA Zero Trust Implementation Guideline Primer formalizes these requirements for national security systems, requiring continuous verification of every network device access request.

5.3 Financial Services Sector, NSPM and Compliance-Driven Management

Organizations operating under PCI DSS, SOX, and DORA requirements treat network device management as a compliance-critical function. Network Security Policy Management (NSPM) platforms are used to manage complex firewall rule sets, perform automated change impact analysis before any network device modification is pushed, and maintain continuous audit trails for regulatory review. The financial sector's emphasis on change management controls, rule lifecycle management, and automated compliance reporting has become a benchmark for other industries managing complex network environments.

6. Current Industry Trends (2026)

This policy is explicitly designed to address the current and near-term cybersecurity landscape. The following trends directly shaped the safeguards defined in Section 7.

6.1 Zero Trust Network Access Is Now Operational Necessity

The principle of never trust, always verify has moved from aspirational framework to operational standard. CISA's Zero Trust Maturity Model and the NSA's January 2026 Zero Trust Implementation Guideline Primer require organizations to enforce continuous authentication and authorization at every network device access point. Static perimeter-based trust models are no longer acceptable. In 2026, Zero Trust means every management session is verified in real time based on identity, device health, geolocation, and behavioral signals. Sessions are automatically terminated when risk indicators change.

6.2 AI-Driven Monitoring and Automated Remediation

IBM research projects that AI-enabled workflows will expand from 3% of enterprise deployments in 2024 to 25% by 2026, an eightfold increase. Modern network monitoring platforms now leverage machine learning to analyze traffic patterns, detect anomalies in real time, perform root cause analysis across network layers and device logs, and in mature deployments trigger automated remediation. Tenable's Chief Security Officer noted in early 2026 that automatic remediation, mobilization, and mitigation are no longer forbidden, a fundamental shift driven by the speed of AI-assisted attacks. This directly strengthens NDM-10 (real-time alerting) and NDM-12 (netflow analysis) as active, AI-augmented controls.

6.3 AI-Accelerated Attack Velocity

Everbridge's 2026 threat landscape analysis predicts that breach-to-impact will be measured in hours as attackers embed AI into their tooling for continuous, automated network reconnaissance and exploitation. Attackers now deploy AI agents that operate around the clock, probing external attack surfaces, chaining exploits, and adapting to defender responses in real time. This makes patching velocity (NDM-14), configuration drift detection (NDM-13), and real-time alerting (NDM-10) time-critical controls rather than routine administrative tasks.

6.4 Identity as the New Network Perimeter

The network perimeter as traditionally understood no longer exists. Identity, both human and machine, is now the primary security boundary. The 2026 RSA Conference identified Identity Fabric as a key trend: integrating PAM systems, IAM, and non-human identity management into a unified, policy-driven layer. For network devices, this means every administrative identity must be managed through a PAM system (NDM-05), every access must require MFA (NDM-06), and every session must be logged and auditable.

6.5 Consolidated Security Architecture, SASE and NSPM

Industry forecasters project significant 2026 investment in consolidating network security into SASE and Zero Trust frameworks. NSPM platforms are being adopted to manage complex network device rule sets, perform automated change analysis, and maintain continuous compliance documentation. Organizations are moving from disconnected point tools toward centralized management systems (NDM-08) that provide unified visibility, automated scanning (NDM-09), and integrated compliance reporting.

6.6 CIS Benchmarks March 2026 Updates

The March 2026 CIS Benchmark updates introduce enhanced guidance for Zero Trust Network Access architectures, container and cloud-native network security, and AI/ML infrastructure protection. For traditional network devices, the benchmarks continue to emphasize immutable configuration baselines, enhanced logging requirements, and continuous compliance validation using automated tooling such as CIS-CAT Pro. These updates directly inform NDM-02's requirement to maintain configuration benchmarks for all authorized network devices.

7. Roles and Responsibilities

The following table defines primary responsibilities for implementing and maintaining this policy. Detailed role descriptions are maintained in the organization's ISMS documentation.

Role	Primary Responsibilities
IT Security Manager	Policy owner; annual review; exception approvals; violation escalation; compliance reporting to leadership
Network Administrator	Implements all NDM controls; maintains device inventory; performs configuration management, patching, and change management
IT Manager	Ensures resource allocation; approves infrastructure changes; reviews exceptions with Security Manager
Security Analyst	Monitors NMS alerts; reviews netflow and log reports; conducts compliance assessments; escalates anomalies
IT Architecture Board	Reviews and approves new network designs to ensure alignment with policy and security standards
All Staff and Contractors	Must not connect unauthorized devices; must immediately report suspected violations to IT Security Manager

8. Policy Safeguards

The following safeguards are derived from the SANS/CRF Network Device Management Policy template (February 2026) and expanded with technical rationale grounded in CIS Controls v8, NIST SP 800-53, and current industry practice. All safeguards are mandatory unless a formal exception has been granted per Section 11.

8.1 Inventory and Configuration Management

Control	Safeguard	Technical Rationale and Industry Alignment
NDM-01	Maintain a complete, current inventory of all approved network devices, including make, model, firmware version, location, and assigned administrator.	CIS Control 1 (Asset Inventory) establishes that you cannot protect what you cannot see. The University of Bristol and federal sector organizations both mandate device inventories as foundational to all other controls. Inventories enable patch tracking, decommissioning decisions, and incident response scoping.
NDM-02	Maintain documented cybersecurity configuration benchmarks aligned to the current CIS Benchmarks for all authorized network device types.	CIS Benchmarks provide vendor-specific, consensus-based hardening guidance updated to reflect current threats. March 2026 updates include enhanced Zero Trust and logging controls. Maintaining documented baselines enables automated drift detection (NDM-13) and demonstrates compliance to auditors.
NDM-13	Use the network management system to perform regular automated comparisons of each device's live configuration against its approved baseline, logging and alerting on any detected changes.	Configuration drift, whether from unauthorized changes, software updates, or human error, introduces vulnerabilities. NIST SP 800-128 mandates configuration monitoring. This control, combined with AI-driven monitoring trends, transforms passive logging into an active defense mechanism.

8.2 Secure Management Access

Control	Safeguard	Technical Rationale and Industry Alignment
NDM-03	Manage all network devices exclusively from a dedicated, approved out-of-band management network subnet, isolated from the production network.	Isolating management traffic prevents attackers who gain access to the production network from reaching device management interfaces, a core Zero Trust principle mandated by NIST SP 800-207. Both Bristol's ISP-12 and the DISA STIG framework require management network isolation for critical infrastructure devices.
NDM-04	Prohibit management of network devices from any remote or Internet-based network without explicit, time-limited exception approval.	Internet-accessible management interfaces represent one of the most exploited attack surfaces in network infrastructure. Multiple CISA advisories have documented nation-state actors exploiting internet-facing router and firewall management ports. This control eliminates that vector.
NDM-05	Require that all network device management access is conducted through an approved Privileged Account Management (PAM) system or dedicated management jump box with full session recording.	PAM systems provide credential vaulting, just-in-time access, and complete session audit trails. The 2026 RSA Conference identified PAM as central to Identity Fabric, the new security perimeter. Session

Control	Safeguard	Technical Rationale and Industry Alignment
		recordings support forensic investigations and demonstrate compliance to auditors.
NDM-06	Require Multi-Factor Authentication (MFA) for all access to network device management interfaces, without exception.	Credential theft remains the leading cause of unauthorized network device access. CISA and NSA guidance mandates MFA for all privileged access to critical systems. In 2026, MFA is baseline hygiene but its absence remains highly exploitable. This control eliminates single-factor credential attacks.
NDM-07	Mandate use of encrypted management protocols (SSH v2 or TLS 1.2 minimum) for all remote device management. Prohibit Telnet, HTTP, and all other unencrypted protocols.	Unencrypted management protocols expose device credentials and configurations to network interception, a risk demonstrated directly in ARP poisoning and man-in-the-middle attacks. SSH and TLS provide encryption in transit, aligning with NIST SC-8 and the DISA Network Device STIG.

8.3 Network Management System and Monitoring

Control	Safeguard	Technical Rationale and Industry Alignment
NDM-08	Maintain a centralized network device management system (NMS) that provides unified administration, monitoring, and reporting for all approved network devices.	Centralized management is foundational to consistent policy enforcement and security visibility. Industry trends in 2026 emphasize consolidation away from disconnected point tools toward unified platforms that reduce operational overhead and eliminate monitoring blind spots.
NDM-09	Configure the NMS to perform regular automated scans for new or unrecognized devices across all network segments, adding discoveries to the inventory and alerting on unauthorized devices.	Rogue device detection is a CIS Control 1 requirement. Unauthorized devices can serve as pivot points for lateral movement. As AI-driven attacks automate network reconnaissance, rapid detection of unauthorized network additions is essential.
NDM-10	Configure the NMS to monitor the operational status and system logs of each network device in real time and generate immediate alerts when a device goes offline or exhibits anomalous behavior.	Unexpected device outages may indicate an attack, hardware failure, or unauthorized change. AI-driven monitoring now supports predictive alerting that identifies precursors to failure before outages occur. Immediate alerting is critical in an environment where breach-to-impact can occur in hours.
NDM-11	Implement IP Address Management (IPAM) through the NMS for all networks, including DHCP scope management, to maintain complete visibility into all network addressing.	Unmanaged IP space creates inventory gaps, unauthorized subnets, and blind spots in security monitoring. IPAM provides the authoritative address inventory required for segmentation enforcement, incident response scoping, and compliance reporting.

Control	Safeguard	Technical Rationale and Industry Alignment
NDM-12	Configure all network devices to export netflow data to the NMS or SIEM system. Retain netflow records for a minimum of 90 days.	Netflow analysis enables detection of anomalous traffic patterns, data exfiltration, lateral movement, and command-and-control communications. AI-driven netflow analysis identifies suspicious patterns that manual review could never detect at scale. Aligns with NIST AU-12 and CIS Control 8.

8.4 Firmware and Lifecycle Management

Control	Safeguard	Technical Rationale and Industry Alignment
NDM-14	Ensure all network devices operate on the latest vendor-supported firmware version. Patch critical and high severity vulnerabilities within 30 days and medium severity within 90 days.	Unpatched network device firmware is one of the most exploited attack vectors. CISA's Known Exploited Vulnerabilities catalog documents dozens of actively exploited CVEs in routers, switches, and firewalls. End-of-life devices must be decommissioned. Patch timeframes align with NIST SP 800-40.

9. Legal and Regulatory Obligations

This policy supports compliance with the following legal, regulatory, and contractual frameworks. A complete legal register is maintained separately by the IT Security and Legal departments.

Framework / Standard	Relevance to This Policy
NIST Cybersecurity Framework (CSF) 2.0	Protect (PR) and Detect (DE) functions, secure configuration, access control, continuous monitoring
NIST SP 800-53 Rev 5	SC (System and Communications Protection), CM (Configuration Management), AU (Audit and Accountability), IA (Identification and Authentication)
CIS Controls v8	Controls 1 (Asset Inventory), 4 (Secure Configuration), 5 (Account Management), 8 (Audit Log Management), 12 (Network Infrastructure Management)
ISO/IEC 27001:2022	Annex A: Network security (A.8.20), Logging (A.8.15), Secure administration (A.8.31), Change management (A.8.32)
NIST SP 800-207 Zero Trust Architecture	Mandates continuous verification for all device access, underpins NDM-03 through NDM-07
DISA Network Device STIGs	Federal baseline hardening requirements for routers, switches, and firewalls, aligns with NDM-02 and NDM-07
Applicable State and Federal Data Protection Laws	Network devices may process or transmit regulated data; their security directly supports data protection compliance

10. Training and Awareness

All personnel with responsibilities under this policy must receive training appropriate to their role:

- Network Administrators: Annual training on secure device configuration standards, the organization's change management procedures, PAM system operation, and incident response procedures specific to network infrastructure.
- Security Analysts: Ongoing training on network threat intelligence, netflow analysis, anomaly detection, and use of the organization's NMS and SIEM tools.
- All Staff and Contractors: General security awareness training covering recognition of unauthorized network devices, the prohibition on connecting unapproved devices to the network, and the procedure for reporting suspected policy violations.

Training completion records are maintained by the IT Security Team, reviewed during annual compliance assessments, and retained for a minimum of three years.

11. Compliance Measurement

Compliance with this policy is assessed through the following scheduled activities:

Activity	Controls Assessed	Frequency
Device inventory audit	NDM-01, NDM-09	Quarterly
Configuration benchmark comparison	NDM-02, NDM-13	Monthly (automated) + Quarterly review
Vulnerability and firmware scan	NDM-14	Monthly
PAM access log review	NDM-05, NDM-06	Monthly
Netflow anomaly review	NDM-12	Continuous (automated) + Monthly report
Protocol audit (confirm no Telnet/HTTP)	NDM-07	Quarterly
Full policy compliance assessment	All NDM controls	Annual

Results are documented, reported to the IT Security Manager, and retained for three years minimum. Material non-compliance findings are escalated to senior IT leadership within 5 business days of identification.

12. Exception Management

Operational or technical circumstances may occasionally necessitate a temporary deviation from one or more requirements of this policy. All exceptions must follow this process:

- The requesting party submits a written exception request to the IT Security Manager documenting the specific control affected, the business justification, a risk assessment

identifying compensating controls, and the requested duration (maximum 90 days per request).

- Exceptions require written approval from the IT Security Manager. Exceptions affecting NDM-06 (MFA), NDM-07 (encrypted protocols), or NDM-03 and NDM-04 (management network isolation) also require senior IT leadership approval due to elevated risk.
- All approved exceptions are logged in the exception register with the justification, compensating controls, approving authority, and expiration date.
- Compensating controls must be implemented and documented before the exception takes effect.
- The exception register is reviewed monthly. Expired exceptions that have not been formally renewed are treated as policy violations.

13. Policy Sanctions

Non-compliance with this policy will result in disciplinary action consistent with the organization's human resources policies. Sanctions are applied consistently and proportionally:

Severity	Consequence
Minor / Unintentional	Mandatory refresher training; written notice placed in personnel file; increased compliance monitoring for 90 days
Moderate / Negligent	Formal written warning; temporary suspension of network device management access privileges; mandatory security review with IT Security Manager
Severe / Willful Violation	Immediate suspension of all administrative access; HR investigation; potential termination of employment or contract
Criminal / Illegal Activity	All above consequences plus referral to law enforcement; legal action under applicable federal and state statutes

14. Continual Improvement

This policy is a living document reviewed at minimum annually. Earlier review is triggered by any of the following:

- A significant change to the organization's network infrastructure, topology, or technology stack
- Discovery of a material security incident involving a network device
- Publication of new or significantly revised CIS Benchmarks, NIST guidance, or applicable industry standards
- Changes to applicable legal or regulatory requirements
- Findings from internal compliance assessments, third-party audits, or penetration testing

The IT Security Manager coordinates annual reviews, incorporates lessons learned from incidents and assessments, benchmarks against peer organizations, and ensures the policy reflects the current threat environment. All revisions are documented in the version history and communicated to all in-scope personnel within 10 business days of approval.

15. Sources and References

The following sources were consulted in the development of this policy and are cited throughout its sections:

Source	URL / Reference
SANS/CRF Network Device Management Policy Template (Feb 2026)	https://www.sans.org/information-security-policy/network-device-management-policy
University of Bristol ISP-12 Network Management Policy (Nov 2025)	https://www.bristol.ac.uk/infosec/policies/network-management-policy/
CIS Controls v8	https://www.cisecurity.org/controls/v8
CIS Benchmarks (March 2026 updates)	https://www.cisecurity.org/cis-benchmarks
NIST SP 800-53 Rev 5	https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
NIST SP 800-207 Zero Trust Architecture	https://csrc.nist.gov/publications/detail/sp/800-207/final
NIST SP 800-40 Rev 4, Patch Management	https://csrc.nist.gov/publications/detail/sp/800-40/rev-4/final
NIST SP 800-128, Configuration Management	https://csrc.nist.gov/publications/detail/sp/800-128/final
NSA/CISA Zero Trust Implementation Guideline Primer (Jan 2026)	https://media.defense.gov/2026/Jan/08/2003852320/-1/-1/0/CTR_ZERO_TRUST_IMPLEMENTATION_GUIDELINE_PRIMER.PDF
CISA Zero Trust Maturity Model v2	https://www.cisa.gov/zero-trust-maturity-model
ISO/IEC 27001:2022 Information Security Management	https://www.iso.org/standard/82875.html
FireMon, Network Security Policy Management in 2025	https://www.firemon.com/blog/network-security-policy-management-nspm-in-2025/
IBM, AI Network Monitoring (2026)	https://www.ibm.com/think/topics/ai-network-monitoring
Everbridge, AI and the 2026 Threat Landscape	https://www.everbridge.com/blog/ai-and-the-2026-threat-landscape/
SentinelOne, 10 Cybersecurity Trends for 2026	https://www.sentinelone.com/cybersecurity-101/cybersecurity/cyber-security-trends/
Motadata, Top Network Monitoring Trends 2026	https://www.motadata.com/blog/network-monitoring-trends/
Tenable / Security Boulevard, Cybersecurity Predictions 2026	https://securityboulevard.com/2026/01/cybersecurity-snapshot-predictions-for-2026
University of Missouri, Network Device Hardening Standard	https://www.umsystem.edu/ums/is/infosec/network-device-hardening-standard
DISA Network Device STIGs	https://public.cyber.mil/stigs/

